



SPR07_외부주문 보안성 평가 절차서 _Ver 0.9

소관부서 : 정보정보보안팀

버전: Ver 0.9

I. 개요

1. 목적
2. 적용범위
3. 용어정의
4. 역할 및 책임

II. 외부주문 보안성 검토 절차

1. 제안요청서(RFP) 발행 및 사전검토 (담당부서)
2. 외부업체 선정 및 제안서 접수
3. 보안성 검토 수행 (정보보안팀)
4. 보안성 검토결과 검토 및 승인 (CISO)
5. 계약 체결 및 보안조항 반영 (컴플라이언스팀/정보보안팀)
6. 구축 및 검수 단계
7. 운영 승인 및 이관

III. 기록관리

[별첨]

I. 개요

1. 목적

본 절차서는 외부업체를 통해 도입되는 IT 설비 및 정보자산(서버, 네트워크, 소프트웨어, 클라우드 서비스 등)에 대하여 보안성 검토 및 승인 절차를 수립함으로써, 회사 정보시스템의 기밀성·무결성·가용성을 유지하고 외부업체 활용에 따른 보안위험을 사전에 예방함을 목적으로 한다.

※ 단, 클라우드 서비스 관련 사항은 「클라우드서비스 이용 매뉴얼」을 따른다. 그 외 설비 및 정보자산은 본 절차에 따른다.

2. 적용범위

본 절차서는 「외부주문보안지침」 제2조에서 정한 정보처리시스템과 관련된 외부주문 계약을 통해 용역, 구축, 개발, 유지보수 등의 서비스를 제공하는 외부업체 및 외부직원을 대상으로 한다.

특히 다음 각 호에 해당하는 사업에 적용한다.

1. 정보처리시스템(서버, 네트워크, 보안장비 등) 도입·구축·개선
2. 소프트웨어 및 응용프로그램 개발 또는 구매
3. 클라우드컴퓨팅 서비스 이용
4. 정보자산 신규 구축 또는 주요 변경이 수반되는 외부주문 사업

※ 단, 클라우드컴퓨팅서비스 도입 및 이용 시에는 「클라우드서비스 이용 매뉴얼」을 우선 적용한다.

3. 용어정의

1. 보안성 검토(Security Assessment): 외부주문 사업 수행 시, 도입 대상 자산 또는 용역의 보안요건 충족 여부를 평가하는 활동
2. 제안요청서(RFP): 외부업체로부터 제안서를 접수하기 위해 작성하는 문서로, 보안요구사항을 포함하여야 함
3. 정보자산(Information Asset): 회사가 업무 수행에 사용하거나 보유하는 데이터, 시스템, 네트워크, 장비, 문서 등 모든 형태의 정보 및 관련 자산
4. 외부주문(Outsourcing): 회사가 제3자에게 IT 관련 용역 또는 시설을 위탁하는 행위

4. 역할 및 책임

구분	주요 역할 및 책임
담당부서(발주부서)	제안요청서(RFP) 발행, 사업 타당성 검토, 외부업체 선정 및 계약 추진, 보안성 검토 신청
정보보안팀(관리부서)	보안성 검토 수행 및 승인, 보안요구사항 검토 및 결과보고
컴플라이언스팀	계약서 내 법적 및 준법 검토, 개인정보보호 및 정보보호 조항 검증
CISO	보안성 검토 결과 최종 승인 및 위험수용 여부 결정
외부업체(수행사)	제안요청서의 보안요구사항을 충족하도록 제안 및 관련 증적 제출

II. 외부주문 보안성 검토 절차

1. 제안요청서(RFP) 발행 및 사전검토 (담당부서)

1. 외부주문 사업 추진 시 담당부서는 제안요청서(RFP)를 작성하여 발행하며, 다음 사항을 포함해야 한다.

- ① 사업 목적 및 범위
- ② 구축 또는 도입 대상 자산
- ③ 정보보안 및 개인정보보호 요구사항
- ④ 납품 일정, 품질 및 검수 기준

2. RFP 발행 전, 정보보안팀(관리부서) 및 컴플라이언스팀의 검토를 거쳐야 한다.

3. RFP 내 보안요구사항에는 보안성 검토 수행 및 승인 절차 반영 여부가 포함되어야 한다.

※ 클라우드서비스 도입 시에는 「클라우드서비스 이용 매뉴얼」의 사전 검토 절차를 따른다.

2. 외부업체 선정 및 제안서 접수

1. 담당부서는 RFP에 따른 제안서를 외부업체로부터 접수하고, 「외부주문관리지침」 제10조의 기준에 따라 수의계약 또는 경쟁입찰 방식으로 업체를 선정한다.
2. 정보보안팀은 제안서에 명시된 보안요구사항 충족 여부를 검토하여 평가항목으로 반영한다.

3. 보안성 검토 수행 (정보보안팀)

1. 정보보안팀은 외부주문 계약 대상의 자산 및 서비스에 대해 '전자금융기반시설 보안 취약점 평가기준(양식)'에 따라 보안성 검토를 수행한다.
2. 평가 결과는 '보안성 검토보고서'로 작성하며, 위험도에 따라 상/중/하 등급으로 분류한다.
3. 보완이 필요한 항목은 외부업체에 개선요청서를 발송하고, 개선 후 재평가를 수행한다.
 - a. 경미한 변경 또는 내부 관리도구 등은 CISO 승인 하에 평가 면제 가능

※ 클라우드서비스 도입 시에는 「클라우드서비스 이용 매뉴얼」에 따른 보안검토 절차를 우선 적용한다.

4. 보안성 검토결과 검토 및 승인 (CISO)

1. 정보보안팀은 평가결과를 종합하여 CISO에게 보고하고, 다음 중 하나로 결정을 요청한다.
 - 승인: 보안요구사항 충족 및 위험 수용 가능
 - 조건부 승인: 개선계획 제출 후 재평가 필요
 - 불승인: 중대한 보안취약점 발견
2. CISO는 필요 시 정보보호위원회 안건으로 상정하여 승인한다.

5. 계약 체결 및 보안조항 반영 (컴플라이언스팀/정보보안팀)

1. 승인된 건에 한해 계약서를 체결하며, 「외부주문관리지침」 제15조에 명시되어 있는 보안 요구사항 포함 여부를 확인 후 계약을 체결한다.

6. 구축 및 검수 단계

- 담당부서는 외부업체가 제출한 산출물 및 구축 결과에 대해 계약서상 검수 기준에 따라 검수를 수행한다.
- 정보보안팀은 필요 시 보안요구사항 이행 여부를 검수 과정에 포함하고, 보안성 검수보고서를 작성한다.

7. 운영 승인 및 이관

- 검수 완료 후, 담당부서 및 정보보안팀은 운영환경 적용 여부를 결정한다.
- 운영 중 신규 취약점이 발생하거나 서비스 변경이 있을 경우, 재평가를 수행한다.

III. 기록관리

- 평가결과보고서, 개선조치결과, 계약서 사본 등은 별도 보관한다.
- 평가 결과는 연간 정보보안점검계획에 반영하여 관리한다.

[별첨]

21. 전자금융기반시설 보안 취약점 평가기준(양식).xlsx

▼ 개정 이력

개정번호	개정 내용 요약	버전	개정일자	담당자
1	최초 제정	1.0	2025-10-24	이윤희